The Phishermen's Intrusion Report #1

Table of Contents

Table of Contents **0**
Overview **1**
Wazuh 1
Mitigating Measures **1**
Active Directory 1
Ticketing Machine 2
Management Backend 2
Admin User Interface 3
Website 3

Attacks **4**
Default Credentials 4
Website Enumeration 6
Conclusion **8**

Overview

Wazuh

We deployed and utilized Wazuh to track all traffic on our networks, and to analyze attacks in greater detail.

Throughout the competition, the Red Team executed attacks that triggered our Wazuh agents. The details of the observed attacks are documented below.

Mitigating Measures

A combined use of a penetration test and analysis of machine settings and codebases identified a myriad of weaknesses in the network.

Active Directory

1. Re-configured incorrectly-configured groups
    a. Removed the `Domain Users` group from the `Domain Admins` group
    b. Removed the `Transit Admins` group from the `Domain Admins` group
    c. Restricted Remote Desktop Protocol (RDP) access to only `IT Administrators`, per the provided Scenario

2. EternalBlue Prevention
    a. Disabled `SMBv1`

Ticketing Machine

1. Removed Malware
    a. Removed `sus.exe` executable from startup, and deleted the executable
2. Audited Users
    a. Removed `backdoor` and `scrat` malicious users
3. Hardened Codebase
    a. Migrated HTTP to HTTPS
    b. Added authentication checks to select endpoints

Management Backend

1. Re-configured allowed elevated permissions
    a. Modified `/etc/sudoers` file to only allow for `IT Administrators` to run commands with elevated permissions
2. Hardened Codebase
    a. Updated SECRET_KEY to use a secure, 32-byte hex string
    b. Disabled Authentication Bypass to Administrator
    c. Disabled Remote Code Execution via Debug Mode

Admin User Interface

1. Removed malware
    a. Deleted malicious `notpad_original.exe` and `backdoor.bat` files
2. Audited Users
    a. Removed `scrat` and `taco` users
3. Hardened Codebase
    a. Updated SECRET_KEY to use a secure, 32-byte hex string
    b. Disabled Remote Code Execution via Debug Mode

Website

1. Removed Malicious LD_PRELOAD nsabackdoor.so
2. Removed three (3) listening ports running netcat (nc), which would allow for an immediate root reverse shell
3. Removed two services in systemd which allow for immediate privileged access
4. Revised /etc/sudoers file to only allow for IT Administrators and root to run commands with elevated permissions
5. Hardened Codebase
    a. Updated SECRET_KEY to use a secure, 32-byte hex string
    b. Migrated from HTTP to HTTPS

Attacks

Our IDS (Wazuh) detected numerous attacks from 0630 to 0900 CST.

Default Credentials

Between `Feb 21 06:30` and `Feb 21 09:00`, Red Team attempted to access our systems using default credentials and previously known malicious usernames. The attempts targeted accounts such as `cdc`, `scrat`, `taco`, and `root`, originating from a small set of IP addresses. The behavior included username rotation and rapid authentication attempts consistent with automated brute-force tooling, such as the behavior of the **isu-cdc-autopwn** brute-force script.

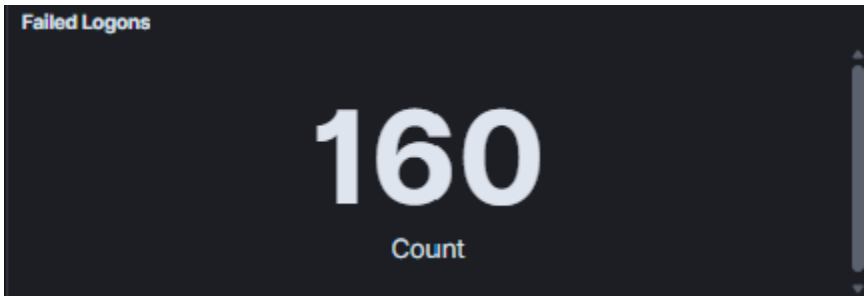
Wazuh generated alerts for:

- Multiple failed SSH authentication attempts from a single source IP
- Excessive authentication failures against a single user
- Distributed authentication failures across multiple hosts
- Windows failed logon events (Event ID 4625)
- Kerberos pre-authentication failures (Event ID 4771)

By centralizing these logs, we were able to correlate activity across systems despite time zone differences on individual hosts. Although some machines displayed timestamps offset

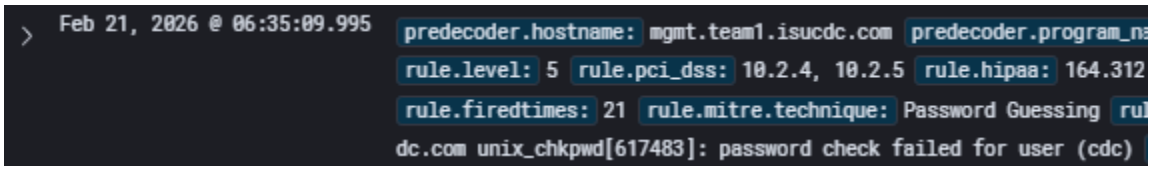
by several hours, the Wazuh manager normalized ingestion times, allowing us to identify the attack window accurately.

The first notification of an incident was a large number of failed logons on our dashboard



Below is a representative sample of our logs

Here is a closer look at one of the entries



In this attempt, a user attempted to authenticate using credentials, which was categorized as a *Password Guessing* MITRE ATT&CK technique.

Outside of Wazuh, we identified failed logins on the systems themselves

```
[root@www ~]# su - cdc
Last login: Sat Feb 21 07:21:26 EST 2026 on pts/0
Last failed login: Sat Feb 21 07:38:46 EST 2026 from 49.10.219.164 on ssh:notty
There were 9 failed login attempts since the last successful login.
```

```
[root@mgmt ~]# su - cdc
Last login: Sat Feb 21 06:22:43 CST 2026 on pts/0
Last failed login: Sat Feb 21 06:38:29 CST 2026 from 49.10.219.164 on ssh:notty
There were 13 failed login attempts since the last successful login.
```

```
[root@www ~]# tail -n 20 /var/log/secure
Feb 21 07:44:35 www sshd[1145194]: pam_sss(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164 user=cdc
Feb 21 07:44:35 www sshd[1145194]: pam_sss(sshd:auth): received for user cdc: 10 (User not known to the underlying authentication module)
Feb 21 07:44:39 www unix_chkpwd[1145203]: password check failed for user (cdc)
Feb 21 07:44:39 www sshd[1145201]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164  user=cdc
Feb 21 07:44:39 www sshd[1145201]: pam_sss(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164 user=cdc
Feb 21 07:44:39 www sshd[1145201]: pam_sss(sshd:auth): received for user cdc: 10 (User not known to the underlying authentication module)
Feb 21 07:44:41 www unix_chkpwd[1145206]: password check failed for user (root)
Feb 21 07:44:41 www sshd[1145204]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164  user=root
Feb 21 07:44:43 www sshd[1145207]: pam_unix(sshd:auth): check pass; user unknown
```

Per our logging, this attempt to gain access to our network had **no impact** on our operations.

Website Enumeration

Red Team took actions in enumerating and testing our website in an attempt to gain access.

The first instance of highly-likely enumeration came when a user with username `trwbox` created an account and authenticated to our website

{"timestamp": "2026-02-21T07:37:29-0500", "level": "DEBUG", "logger": "urllib3.connectionpool", "message": "http://199.10
0.16.100:3128 \"POST http://64.39.3.30:5000/auth/register HTTP/11\" 409 34"}
{"timestamp": "2026-02-21T07:37:29", "level": "INFO", "logger": "root", "message": "http_request", "request_id": "0ac3602
5", "event_type": "frontend_http_request", "endpoint": "register", "http_method": "POST", "url_path": "/register", "query
_params": {}, "src_ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com", "response_status": 204, "response_time_ms": 1842
6.19, "user_agent": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:147.0) Gecko/20100101 Firefox/147.0", "referer": "h
ttp://www.team1.isucdc.com/register", "origin": "http://www.team1.isucdc.com", "content_type": "application/x-www-form-ur
lencoded", "content_length": 39, "session": {"username": "trwbox"}, "url_params": {}}
{"timestamp": "2026-02-21T07:37:33-0500", "level": "DEBUG", "logger": "urllib3.connectionpool", "message": "http://199.10
0.16.100:3128 \"GET http://64.39.3.30:5000/payment-info/ HTTP/11\" 404 34"}
{"timestamp": "2026-02-21T07:37:33", "level": "INFO", "logger": "root", "message": "http_request", "request_id": "0e01e81
b", "event_type": "frontend_http_request", "endpoint": "get_payment", "http_method": "GET", "url_path": "/get_payment_inf
o", "query_params": {}, "src_ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com", "response_status": 200, "response_time
_ms": 18835.69, "user_agent": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:147.0) Gecko/20100101 Firefox/147.0", "re
ferer": "http://www.team1.isucdc.com/profile", "origin": "", "content_type": null, "content_length": null, "session": {"u
sername": "trwbox"}, "url_params": {}}

Here is a closer look at the log

{}, "src_ip": "127.0.0.1", "dst_host": "w
"user_agent": "Mozilla/5.0 (Macintosh; In
"http://www.team1.isucdc.com/register",
{"username": "trwbox"}, "url_params": {}}

`trwbox` is a known username of Red Team member Trent

Another known member, Tom Pohl, was identified performing reconnaissance

"root", "message": "http_request", "reques
"get_tickets", "http_method": "GET", "url_
"dst_host": "www.team1.isucdc.com", "resp
.0 (Macintosh; Intel Mac OS X 10_15_7) App
referer": "http://www.team1.isucdc.com/tic
ssion": {"username": "tompohl"}, "url_para

In addition to manual use, automated scans were performed, notably with nmap. Because nmap uses a User Agent with the term “nmap”

```
arams": {}}
026-02-21T07:38:59", "level": "INFO", "logger": "root", "message": "http_reque
ent_type": "frontend_http_request", "endpoint": "index", "http_method": "GET"
{}, "src_ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com", "response_statu
 "user_agent": "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.
 "origin": "", "content_type": null, "content_length": null, "session": {"use
```


Per our logging, this attempt to gain access to our network had **no impact** on our operations.

Conclusion

Actions were taken to compromise our network; however, no attacks taken were successful. As such, our network remains stable and secure.